



RANSOMWARE ATTACK ON SÜDWESTFALEN-IT COMPANY

Case Study Report

4th April 2024

Vairav Technology Security Pvt. Ltd.

Thirbam Sadak 148

Baluwatar, Kathmandu

Phone: +977 4541540

Mobile: +977-9820105900

Email: mail@vairav.net

FOREWORD

This report provides an insight about a ransomware attack on Südwestfalen-IT (S-IT), a provider of infrastructure and software solutions for municipalities and non-profit organizations. The incident, initiated by the Akira ransomware group, exploited vulnerabilities in S-IT's system, resulting in significant operational disruptions. The report delves into the attack progression, forensic analysis, and containment efforts undertaken by r-tec, an external cybersecurity firm.

Key findings

- The initial entry vector through a VPN vulnerability, lateral movement within the network, and post-exploitation activities aimed at data exfiltration and ransomware deployment
- Despite an indication of data preparation, no concrete evidence of exfiltration found till date

This report aims to provide a detailed account of the incident, including the attack progression, containment efforts, and findings from the forensic analysis. Outlining the measures undertaken to strengthen the infrastructure and enhance resilience against similar threats, the report contributes to the broader cybersecurity community's understandability of such attacks.

TABLE OF CONTENTS

CHAPTER 1: INTRODUCTION.....	4
CHAPTER 2: DESCRIPTION OF THE INCIDENT	4
CHAPTER 3: ANALYSIS OF CAUSES	6
3.1 Initial entry vector	6
3.2 Lateral Movement.....	7
3.3 Post-exploitation	8
CHAPTER 4: IMPACT AND CONSEQUENCES	9
CHAPTER 5: LESSON LEARNED	11
CHAPTER 6: RECOMMENDATION	12
6.1 Short-term Measures	12
6.2 Medium-term Measures	13
6.3 Long-term Measures:.....	14
CHAPTER 7: CONCLUSION	14
CHAPTER 8: REFERENCES	15

CHAPTER 1: INTRODUCTION

On October 29, 2023, Südwestfalen-IT fell victim to a ransomware attack that significantly impacted their operations and the services provided to their customers and citizens. An infrastructure operator and software company, the firm specializes in providing innovative solutions for municipalities and non-profit organizations, contributing to the improved efficiency and convenience for residents. However, with their swift response, they effectively ceased the attack, minimizing the overall damage incurred.

Furthermore, with the assistance of external cybersecurity experts, they conducted a thorough forensic investigation to analyze the attack vectors and bolster their security measures. During the security incident, r-tec was tasked with conducting the forensic investigation and containment, alongside assisting in the reconstruction and restart of the infrastructure and applications.

CHAPTER 2: INCIDENT DESCRIPTION

The attack was executed by a criminal ransomware group referred to as “**Akira**”, who exploited the vulnerabilities of Südwestfalen-IT’s system. At first, the firm detected the encrypted files on Sunday, October 29, 2023, to Monday, October 30, 2023, which had **.akira file extension** associated with the “**Akira**” ransomware group.

At around 12:30 am, the internal experts of Südwestfalen-IT responded back with initial steps to contain the anomalies, analyzing them while shutting down the overall systems to prevent the further damage. Upon further analysis, it was found that the attackers exploited a **zero-day vulnerability** in a software-based VPN solution to infiltrate the internal network.

Although, the forensics reckoned that a potential brute-force attack may have occurred, as the attackers primarily targeted the Windows domain intra.lan, which is responsible for managing central systems and critical procedures for the overall Südwestfalen-IT customers.

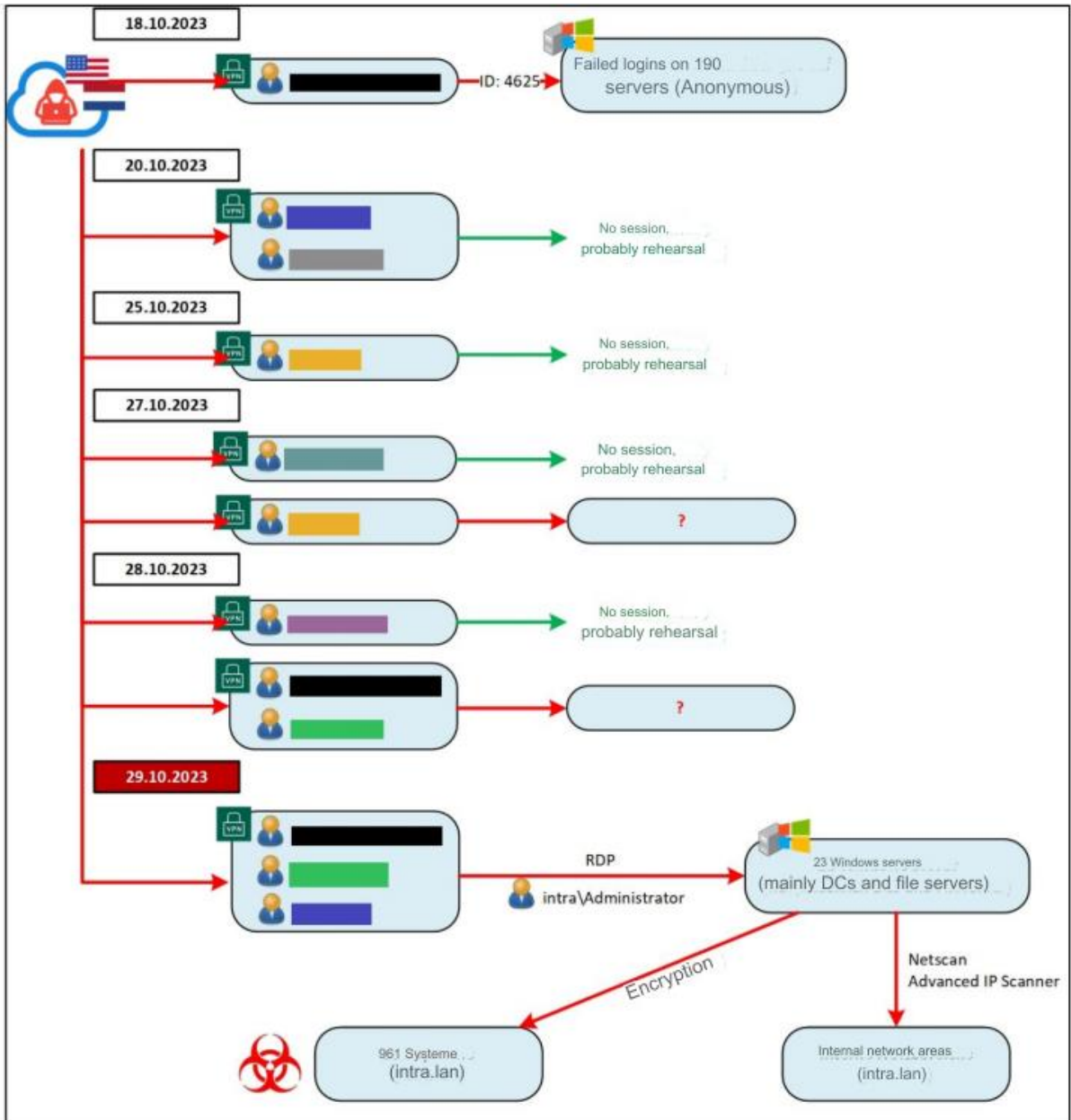


Figure 1: Incident Timeline

CHAPTER 3: CAUSE ANALYSIS

3.1 Initial Entry Vector

During the initial phase of the forensic investigation, r-tec focused on identifying the entry vector of the attack.

Several factors contributed to the vulnerability exploited by the attackers, as listed beneath:

3.1.1 Brute Force Attack via VPN: A surge in **failure of VPN logins** shortly before the initial access indicated a potential brute force attack. Despite being common on publicly accessible systems, specific conditions drew attention to this possible entry point. The combination of **vulnerable firewall firmware** and the **absence of two-factor authentication** heightened the risk of compromised VPN user accounts being exploited, aligning with the typical **approach of the Akira** ransomware group.

3.1.2 Analysis of Cisco ISE Logs: Anomalies in **login behavior** were observed in **Cisco ISE logs**, during a specific timeframe on October 18, 2023. Multiple VPN logins were attributed to the attacker, with concurrent usage of various user accounts. While **successful logins** were recorded for **one user** account, several **unsuccessful attempts** were noted for others, indicating potential unauthorized access.

3.1.3 Phishing and Dark Web Exploitation: Although phishing campaigns and dark web data trading were considered the potential sources of compromised credentials, further investigations yielded no evidence of recent phishing attacks or compromised user accounts on the dark web. Despite extensive analysis, no indications of successful phishing attacks or compromised credentials from the dark web were found.

3.1.4 The exploitation of CISCO ASA Vulnerability: Exploiting a **zero-day vulnerability** in CISCO ASA (CVE-2023-202691.2) depicted another likely entry point for the attackers. Previously exploited by the Akira ransom group, this vulnerability allowed the proceedings of the brute force attacks against various usernames and passwords. The use of **vulnerable CISCO ASA** version 9.12(3)7 further increased the likelihood of successful brute force attacks.

3.1.5 Challenges in Log Data Analysis: With limitations in the available log data that extended only till October 6, 2023, hindered the comprehensive analysis of brute force activities before the due date. This indicated that the older data may have been overwritten, potentially obscuring previous attack attempts. The dynamic assignment of internal IP addresses post-VPN login complicated the investigation, making it fairly challenging to trace the attacker's movements within the firm's network.

3.1.6 Geographical Complexity: A cluster of multiple login attempts from outside Germany posed challenges in distinguishing the legitimate IP addresses, from the IP addresses of the attackers. As the German IP addresses could potentially mask malicious activities, it complicated the forensic analysis. Despite these challenges, r-tec successfully traced several attacker VPN sessions, providing valuable insights into the potential entry points exploited by the attackers.

3.2 Lateral Movement

Despite limitations in the historical event logs and incomplete forensic evidence, r-tec's investigation uncovered several key findings indicative of lateral movement, as listed beneath:

3.2.1 Automated Login Attempts: Analysis revealed that **380 failed Anonymous-SMB login attempts** were made on **190 servers** within the intra.lan network. These attempts, executed via **two separate VPN sessions** from local IP addresses, indicated a systematic approach to accessing multiple systems simultaneously; a common tactic in lateral movement strategies.

3.2.2 Parallel VPN Sessions: The attacker utilized **4 VPN sessions** with **3 different user accounts** on October 29, 2023, shortly after establishing the initial VPN connection. This simultaneous use of multiple sessions indicates an orchestrated effort of lateral movement across the network, swiftly and covertly.

3.2.3 Access to Critical Systems: Within minutes of the **initial RDP** access to a **domain controller** using the "intra.lan\Administrator" account, the attackers gained access to additional **22 systems**, predominantly domain controllers. This rapid progression highlights the attacker's intent for escalation of privileges and compromise of critical infrastructure.

3.2.4 Identification of Critical Vulnerabilities: Through an alternative exploratory approach, r-tec discovered a critical security flaw within the Windows domain “intra.lan”, wherein the domain administrator’s password had been stored in **plaintext** within a Group Policy Object (GPO), since 2014. This vulnerability facilitated lateral movement without leaving typical forensic traces, emphasizing the importance of proactive vulnerability management.

3.2.5 Potential Scenarios: While the exact methods of lateral movement remain unclear as of insufficient forensic evidence, two likely scenarios emerge: **inadequate logging mechanisms** within the organization may have masked critical traces of the attacker’s lateral movement, or the attacker may have exploited the **pre-existing vulnerabilities** to gain administrative privileges within the network.

3.3 Post-exploitation

On October 29, 2023, following the establishment of VPN logins using the 3 accounts, the attackers proceeded with post-exploitation activities, which are as listed beneath:

3.3.1 RDP Connections and Reconnaissance: Shortly after successful RDP connections to multiple domain controllers using the “intra.lan\Administrator” account, the attackers leveraged **Dual-Use** of the software **NetScan** on the domain controller at 12:26 PM, identifying accessible or writable network shares. These actions directly executed over VPN from the attacker’s systems, facilitating network reconnaissance without leaving Command and Control (C2) connections, thereby complicating analysis efforts.

3.3.2 Data Exfiltration Preparation: R-tec suspected the attacker’s reconnaissance results that served as potential targets for ransomware deployment. Notably, the program **WinRAR.exe** was initiated and subsequently crashed on the **file server** in one of the intra.lans, suggesting the possible preparation for **data exfiltration**. Although resembling tactics employed by the Akira Ransom Group, no evidence of actual data exfiltration was found.

3.3.3 Further Reconnaissance and Credential Theft Attempts: The attackers utilized an advanced IP scanner, attempting to extract Veeam credentials from the system of .intra.lan along with publicly available tools, as identified through the PowerShell history of the

domain administrator. These actions aimed to gather additional information and credentials for potential future exploitation.

3.3.4 Windows Defender Exclusion and Ransomware Deployment: The attackers created an **exception in Windows Defender** on several domain controllers, excluding the entire C:\ partition from malware scans. This allowed the deployment and execution of the ransomware, w.exe undetected on various systems, ensuring the widespread encryption of files without triggering any security alert.

3.3.5 Selective Ransomware Placement: The ransomware w.exe was selectively deployed on specific systems, where Windows Defender exclusions were configured, limiting the **detection and mitigation** efforts. The deployment strategy targeted active and network-accessible systems, confirmed by the absence of ransomware on inactive devices.

3.3.6 Execution and Encryption: Analysis of the ransomware revealed **self-generated log** files documenting its actions and errors encountered during encryption. Despite partial encryption of log files, key information regarding the encryption process was retrievable. The ransomware encrypted **targeted systems** recursively via **network shares**, leveraging a list of target systems, likely obtained through **reconnaissance tools**.

CHAPTER 4: IMPACT AND CONSEQUENCES

During the forensic investigation, a potential indication of preparation for possible data exfiltration emerged. It related to a usual activity of the Akira Ransom group; the use of WinRAR to compress sensitive information. An unsuccessful attempt to use a WinRAR executable by the attackers was identified on the file server of **INTRA.LAN**. However, there were no further impactful signs that signified the actual use of WinRAR or actual data exfiltration.

Furthermore, no suspicious web traffic was detected while examining the deployed web proxies, which signified to a potential data exfiltration. Despite the lack of specific evidence of data exfiltration, there was an assumption that methods or tools may have been used to transfer sensitive data.

Since October 30, 2023, r-tec has been proactively monitoring the blog of the attacker group. This **blog** includes the publication of successful attacks on organizations and leaks of data from affected victims. So far, Südwestfalen-IT has pinpointed several new victims and added leaks since then.

Besides, specialized **dark web monitoring** software is being used to search the dark web for keywords, personal names, email addresses, and domains associated with Südwestfalen-IT. However, this measure has not provided any evidence of data publication till date. Despite the efforts, a definitive guarantee for data exfiltration cannot be provided. Potential data publication remains possible, but is considered unlikely by r-tec.

CHAPTER 5: LESSON LEARNED

The security incident that occurred within the network of Südwestfalen-IT (S-IT) provides several insights for enhancing cybersecurity practices and mitigating future risks. These lessons encompass various aspects of cybersecurity management, incident response, and proactive security measures, and are listed as beneath:

5.1 Enhanced Monitoring and Logging: The incident highlights the critical importance of robust **monitoring and comprehensive logging** within the organizational networks. Due to the limited historical event logs that hinder the ability to reconstruct the attacker's complete behavior, organizations should ensure the implementation of effective monitoring tools and logging mechanisms so to capture and retain essential security-related data adequately.

5.2 Proactive Vulnerability Management: Adopting a proactive approach to vulnerability management can help identify and remediate potential weaknesses before attackers exploit them. R-TEC's alternative investigative approach that focuses on identifying exploitable vulnerabilities within the domain, underscores the importance of proactive security assessments and patch management strategies.

5.3 Privilege Management and Access Control: Strengthening **privilege management** practices and access controls is crucial for preventing unauthorized lateral movement and privilege escalation within the network. The discovery of plaintext storage of domain administrator credentials emphasizes the need for **secure credential storage** mechanisms, and regular access reviews to minimize the risk of credential misuse by attackers.

5.4 Incident Response Preparedness: The incident underscores the significance of having a robust incident response plan in place, including clear procedures for detecting, analyzing, and mitigating the security breaches. Organizations should regularly test their incident response capabilities through simulations and drills, ensuring readiness response to cyber threats effectively.

5.5 Threat Intelligence and Monitoring: Continuous monitoring of threat intelligence sources including dark web monitoring, can provide valuable insights into emerging threats and potential risks to the organization. Südwestfalen-IT's proactive monitoring of threat

actor blogs and dark web activities demonstrates the importance of leveraging threat intelligence to anticipate and mitigate cyber threats effectively.

5.6 Data Protection and Privacy: Organizations must prioritize data protection and privacy measures to safeguard sensitive information from unauthorized access and exfiltration. While no concrete evidence of data exfiltration was found, the potential risk of data exposure underscores the importance of robust data protection controls and encryption mechanisms.

The security incident encountered by Südwestfalen-IT serves as a sobering reminder of the ever-present cyber threats faced by organizations today. By embracing these lessons learned and implementing proactive security measures, organizations can better defend against future cyber-attacks, mitigating their potential impact on business operations and data integrity.

CHAPTER 6: RECOMMENDATION MEASURES

Tailored specifically to systems in potentially compromised network zones as well as newly established systems and networks, the recommendation measures are the security strategies as proposed by **r-tec**.

The recommendations are categorized into three groups:

6.1 Short-term Measures

- **Forensic Scan:** Conduct THOR scans on overall systems in affected network areas to detect malicious activities. Implement conditional security classification for systems with unremarkable results.
- **Backup Restoration:** Prioritize restoring systems from backups, as compromise before the date is deemed unlikely.
- **Network Segmentation:** Introduce physical and virtual separation of systems and define access controls.

- **Next-Generation Firewall:** Configure strict access rules to minimize threats and control data traffic.
- **System Hardening Best Practices:** Implement basic security measures such as role and permission concepts and disable unnecessary services.
- **User Account Security:** Implement strong password policies and multifactor authentication, especially for administrative accounts.
- **Endpoint Detection and Response (EDR):** Deploy an EDR solution to detect and respond to abnormal behavior.
- **Logging:** Capture and centrally store security-relevant system and network activities.
- **VPN Solution Replacement:** Rebuild the VPN infrastructure using up-to-date patch technology and multi-factor authentication.
- **Dark Web Monitoring:** Monitor the dark web during forensic investigations.

6.2 Medium-term Measures

- **Extended Network Segmentation:** Develop a comprehensive segmentation concept and micro-segmentation for critical areas.
- **Firewall Optimization:** Analyze encrypted traffic and adjust the firewall settings regularly.
- **Extended System Hardening:** Develop and implement the advanced security standards for various system types.
- **Extended User Account Security:** Implement multifactor authentication measures for all users and evaluate specific solutions for privileged access.
- **Extended EDR Measures:** Deploy additional protection modules within the EDR solution to analyze anomalies comprehensively.
- **Extended Logging:** Introduce a Next-Generation SIEM system for automated analysis of large datasets.

- **Vulnerability Management:** Conduct regular vulnerability scans in overall network areas, regardless of their zoning.
- **Continued Dark Web Monitoring:** Continue monitoring specific search terms on the dark web, despite completing forensic analyses to detect future threats before the monitoring.

6.3 Long-term Measures:

- **Cyber Security Plan:** Long-term development of the organization, processes, and IT security architecture to maintain state-of-the-art **security standards** permanently.
- **Network Security Consolidation:** Integration of **VPN into existing Next-Gen Firewall**, replacement of the existing proxy solution, and hybrid securing of web access for mobile and stationary systems.
- **Strategic Identity and Access Management:** Development of a new role and permission concept in conjunction with a tiering model in the AD, and implementation of a solution for managing privileged access in conjunction with **SSO** (Single sign-on).
- **Penetration Tests / Red Teaming:** Regular examination of the overall parts of the organization using typical methodology of the attacker groups based on 3-year plans, including both internal and external attacks at various levels, along with different target areas.

These recommendations aid to address immediate security risks, enhance resilience against future incidents, and establish a long-term security strategy aligned with organization's objectives and requirements. Implementing these measures will contribute to strengthening the organization's overall security posture and mitigating potential cybersecurity threats effectively.

CHAPTER 7: CONCLUSION

The security incident experienced by Südwestfalen-IT underscores the critical importance of robust cybersecurity practices in today's digital realm. Through swift response and collaboration with external experts like r-tec, Südwestfalen-IT successfully contained the

attack, conducted thorough forensic investigations, and implemented measures to enhance security resilience.

Analyzing the incident emphasizes the need for proactive monitoring, vulnerability management, privilege management, incident response preparedness, and continuous threat intelligence monitoring. By embracing these recommendations and analytics, Südwestfalen-IT can fortify its defenses against future cyber threats, safeguard business operations, and uphold data integrity, contributing to a more secure digital environment for its customers and stakeholders.

CHAPTER 8: REFERENCES

https://notfallseite.sit.nrw/fileadmin/user_upload/SIT_Incident_Response_v1.1.pdf

https://notfallseite.sit.nrw/?tx_news_pi1%5Baction%5D=detail&tx_news_pi1%5Bcontroller%5D=News&tx_news_pi1%5Bnews%5D=774&cHash=272541bf434ca0c20b1db7f36429535f

CONTACT US

Vairav Technology Security Pvt. Ltd.

Cyber Defender from the land of Gurkha

Thirbam Sadak 148, Baluwatar

Kathmandu, Nepal

Phone: +977-01-4541540

Mobile: +977-9820105900

Email: mail@vairav.net

Website: <https://vairav.net>